园区网自动化安全评估系统 (HCL-H3C版) 产品需求文档 (PRD)

1. 项目背景与目标

本项目旨在构建一个基于 Python 的自动化工具，能够针对 H3C 架构的园区网络进行全层级的安全风险摸排。通过自动化采集配置、智能识别设备角色、量化评估风险，最终输出具备专业加固建议的评估报告。

2. 系统架构设计

2.1 技术栈选型

- **开发语言**：Python 3.x
- **通信库**：`Netmiko` (底层支持 `hp_comware`)
- **并行框架**：`concurrent.futures.ThreadPoolExecutor`
- **配置/规则存储**：YAML (用于设备清单、检测规则、加固模板)
- **报告格式**：Excel/PDF (管理视角), JSON/CSV (技术视角)

2.2 核心模块图

1. **输入模块**：读取设备清单与全局配置。
2. **引擎模块**：处理多线程调度、连接重试、限速控制。
3. **识别模块**：通过配置特征匹配判定设备角色（接入/汇聚/核心）。
4. **评估模块**：根据角色调用 `rules.yaml` 中的 Regex 进行匹配与加权计分。
5. **输出模块**：渲染可视化报告与轻量级数据文件。

---

3. 详细功能需求

3.1 设备连接与并发管理

- **认证方式**：支持静态配置文件录入 IP、用户名、密码。
- **重试机制**：连接失败自动重试 **3次**，若均失败则标记 `Connection Error` 并记录至日志。
- **并发控制**：
- 支持 `max_workers` 并发线程设置。
- **配置化限速**：支持 `batch_delay` 参数，每批次任务完成后强制休眠，防止 HCL 模拟器 CPU 崩溃。

3.2 智能角色识别 (Feature-Based)

系统登录后需自动下发 `display` 命令，根据以下特征匹配设备角色：

- **接入层 (Access)**：接口配置中包含大量 `port link-type access` 或 `stp edged-port`。
- **汇聚/核心层**：存在多个 `Vlan-interface` 且配置了动态路由协议（OSPF/BGP）或 `vrrp`。

3.3 安全检测指标体系 (部分示例)

根据设备角色应用不同的 `rules.yaml` 权重模板：

层级	检测项	关键命令	判定逻辑 (Regex)
通用	弱口令/本地用户	`display local-user`	检查是否存在 admin/admin 或简单字符
通用	日志审计	`display current-configuration`	匹配 `info-center enable`
接入层	STP安全	`display stp`	检查 `bpdu-protection` 是否全局开启
接入层	DHCP Snooping	`display dhcp snooping`	检查功能开启及 Trust 端口配置
核心层	ACL策略	`display acl all`	检查是否配置了管理平面访问控制

3.4 风险评估模型

- **评估方式**：**分角色加权计分制。**
- **计分逻辑**：总分 100 分，根据命中风险项的权重扣分。
- **等级定义**：
- **高风险**：总分 < 60 或 命中“致命项”（如核心层弱口令）。
- **中风险**：60 ≤ 总分 < 85。
- **低风险**：总分 ≥ 85。

---

4. 数据字典与规则配置 (`rules.yaml`)

为了保证可维护性，规则需按下述结构解耦：

```yaml
# 规则文件示例结构
roles:
  access:
    items:
      - id: "STP_01"
        desc: "BPDU保护"
        check_cmd: "display current-configuration"

```

```yaml
        regex: "stp bpdu-protection"
        weight: 15
        fix_template: "system-view \n stp bpdu-protection"
  core:
    items:
      - id: "ACL_01"
        desc: "管理平面访问控制"
        ...
```

---

5. 输出需求

5.1 分级汇总报告 (Excel/PDF)

- **首页**：全网安全仪表盘（平均分、风险分布饼图）。
- **详情页**：按设备列出具体扣分项、风险描述及**通用加固模板**。

5.2 轻量级清单 (JSON)

- 输出结构化的 JSON 数据，包含 `device_ip`, `role`, `score`, `failed_items` 等字段，便于后续二次开发或集成。

---

6. 非功能性需求

- **可靠性**：脚本不得因单台设备连接失败而崩溃。
- **准确性**：正则表达式需适配 H3C Comware V7 版本的命令输出。
- **安全性**：脚本在本地运行时，不应明文打印敏感凭据。